Chapter 07

Linux Security & Hardening

Episode 7.01

Episode title: **Security Concepts**

Objective: 3.1

Intro to Security Concepts

Foundation of protecting

Linux systems

Layered approach

All about reducing Risk

Threats, Vulnerabilities, and Risk

Threat actors

Vulnerabilities

Risk assessment

Mitigate / Accept / Transfer / Avoid

Core Security Principles

Least privilege

Defense in depth

Separation of duties

Secure defaults

Security Controls

Administrative controls

Technical controls

Physical controls

Testing and auditing

Episode 7.02

Episode title: **Authentication & Authorization**

Objective: 3.1

Identity and Access

Authentication

Authorization

Linux+ Domain 3.1

Authentication Concepts

Identity verification

Authentication factors (passwords, keys, MFA)

PAM and local vs centralized auth

Polkit and Fine-Grained Authorization

Polkit controls privileged actions

Used by desktop and system services

Fine-grained authorization rules

Complements sudo

Centralized Authentication & Authorization (Exam)

Local vs centralized authentication

Enterprise identity integration

Single sign-on (SSO) concepts

Common exam scenario: Linux joined to a domain

Directory & Domain Services on Linux (Exam)

LDAP – Central directory service

Kerberos – Secure authentication protocol

Samba – Windows interoperability

SSD / Winbind – Identity service integration

Realm – Join and manage domains

Authorization Concepts

File permissions & UIDs/GIDs

POSIX ACLs

Sudo and privilege escalation

SELinux/AppArmor (MAC)

Accounting and the AAA Model

Accounting

Auditing

AAA framework

Accounting & AAA (DEMO)

Accounting

Auditd, journald, rsyslog

DEMO: End-to-end

AAA walkthrough

Episode 7.04

Episode title: **OS Hardening**

Objective: 3.3

OS Hardening Overview

OS Hardening

Deliberate repeatable process

Reduces attack surface

Permissions, Ownership & umask

File permissions (rwx)

Ownership (UID/GID)

umask and automated audits

POSIX ACLs when needed

Special Permissions & SUID Hardening

Special Permissions:

- setuid
- setgid
- Sticky bit

Security implecations

Remove unnecessary SUID binaries

File Attributes and Extended Protection

Extended files attributes – chattr

Modify attributes – lsattr

View attributes – immutable and append-only flags

Sudo, PAM & Privilege Controls

Minimal sudoers

visudo and logging

PAM modules (fail lock, pwquality)

Disable root SSH; use MFA. for admin

SELinux/AppArmor, Boot Security & Patching

SELinux/AppArmor (MAC)

Bootloader & kernel protections

Patch management & signed repos

Secure Boot and UEFI

Secure Boot verifies boot components

Uses UEFI firmware

Protects against boot-level malware

Part of system trust chain

Disabling Unused Filesystems

Reduce attack surface

Disable unused filesystem modules

Prevent mounting of legacy filesystems

Common hardening step

OS Hardening (DEMO)

Baseline snapshot

umask & permission remediation

sudo tuning

SSH hardening

SELinux tuning

Patching

Episode 7.06

Episode title: **Firewall Management**

Objective: 3.2

Firewall Management Overview

Protects from network threats

Filter traffic

Starts with a policy

Firewall Fundamentals

Stateful vs stateless

Default-deny posture

Zones, persistence, logging, rollback

Netfilter Framework

Netfilter is the Linux firewall framework

Kernel-level packet filtering

Foundation for iptables and nftables

Handles connection tracking and NAT

Ports vs Services in Firewalls

Ports – Numeric network endpoints

Services – Named port groups

firewalld service abstraction

Choosing ports vs services

IP Forwarding & Routing

Forwarding Packets between interfaces

Controlled by Kernel parameter

net.ipv4.ip_forward

Required for routing and NAT

firewalld & nftables Concepts

Zones & services (firewalld)

nftables primitives: tables/chains/sets

Runtime vs permanent, verification

firewalld Rich Rules

Advanced rule syntax

Conditional filtering

Logging and rate limiting

Used for complex scenarios

ufw, iptables, NAT & Advanced Topics

ufw basics

iptables vs nftables

NAT, connection tracking, performance considerations

Ipset and Dynamic Firewall Sets

ipset manages IP address sets

Efficient bulk rule management

Often used with iptables or nftables

Dynamic blocking scenarios

Firewall Management (DEMO)

firewalld runtime & permanent

nftables add & rollback

ufw allow/deny & cleanup

Verification & logging

Episode 7.07

Episode title: **Remote Access Security**

Objective: 3.1

Remote Access Security Overview

Increasing reliance

- Remote access
- Remote Management

Minimize remote attack surface

Protect admin and user accounts

SSH Hardening

Key-based auth, disable root login

sshd_config directives (PermitRootLogin, PasswordAuthentication, AllowUsers)

Key management &

certificates, logging

Advanced Secure Remote Access

SSH agent key for management

SSH tunneling and port forwarding

SFTP with chroot directories

Secure administrative access

Disable Insecure Protocols & Access Controls

Remove Telnet/rsh, use SSH/SFTP/VPN

Firewall/admin network restrictions

Jump hosts, session recording

fail2ban & Automated Protections

fail2ban jails andfilters

Tuning bantime/

indtime/maxretry

actions & auditing, limitations

Remote Access Security (DEMO)

Lorem ipsum dolor sit amet

- Bullet 1
  - Sub-bullet 1

Lorem ipsum dolor sit amet

- Bullet 1
  - Sub-bullet 1

Episode 7.09

Episode title: **Logging & Auditing**

Objective: 3.3

Logging & Auditing Overview

Backbone of detection

Supports IR and compliance

Dependent on Authorization

Nonrepudiation

Linux Log Locations

Var/log

- Traditional log location

Journald binary logs

- Application-specific subdirectories

Exam focus:

- where logs are stored

systemd-journald & journalctl

Structured logs and metadata

journalctl filtering and output formats

Persistence and storage limits

rsyslog, Remote Logging & Rotation

Forwarding over TLS

imjournal/imuxsock and omfwd

logrotate and retention policies

auditd & Forensic Tools

Syscall vs file-watch rules

ausearch and aureport usage

Performance trade-offs and forwarding

auditd Config Files

audit.rules – Persistent audit rules

File watches and syscall rules

Loaded at auditd startup

Central to compliance auditing

Logging & Auditing (DEMO)

journald persistence and queries

rsyslog TLS forwarding

auditd rules & ausearch

logrotate and archive

integrity checks